

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 11

Domain III - Information Security Program

50 Questions	80 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 80 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM3-058)

Scenario: A medical equipment company is adding remote monitoring subscriptions to its traditional product business. Its existing security program focuses almost entirely on office technology.

What should be the PRIMARY basis for updating program objectives?

- A. The features included in the security team's preferred products
- B. The practices used by the company's largest competitor
- C. The subscription model's critical services, information, obligations, dependencies, and risks
- D. The controls that can be added without involving product teams

Question 2 (CISM3-059)

Scenario: A humanitarian organization allows country offices substantial autonomy. Security initiatives stall because local directors and headquarters disagree about decision authority.

Which charter action should the information security manager take FIRST?

- A. Issue detailed technical procedures without local consultation.
- B. Let each country office define an unrelated security mandate.
- C. Ask internal audit to manage the security program.
- D. Develop an approved charter defining enterprise authority, local responsibilities, scope, objectives, and escalation.

Question 3 (CISM3-060)

Scenario: A manufacturer plans connected maintenance systems at several plants. Its roadmap includes device inventory, network governance, supplier assurance, monitoring, and workforce training, but funding arrives in two stages.

How should the manager sequence the roadmap?

- A. Begin with the initiative having the most visible dashboard.
- B. Prioritize by risk reduction, capability dependencies, deployment milestones, and available capacity.
- C. Fund projects in alphabetical order to demonstrate neutrality.
- D. Delay foundational capabilities until all plants are connected.

Question 4 (CISM3-061)

Scenario: A restaurant brand operates both corporate and franchised locations. All locations use the brand's ordering platform and process loyalty data, but franchisees manage their own local networks.

Which scope decision is MOST appropriate?

- A. Include shared risks, define corporate and franchise duties, and set interface requirements.
- B. Exclude franchise locations because their networks are locally owned.
- C. Make the ordering-platform operator responsible for every franchise risk.
- D. Include only locations that have previously reported incidents.

Question 5 (CISM3-062)

What should MOST influence staffing for a security capability that must operate continuously?

- A. The number of employees in the finance department
- B. The security manager's historical staffing request
- C. Expected workload, service levels, skill coverage, resilience needs, and sourcing options
- D. The average cost of unrelated technology projects

Question 6 (CISM3-063)

Scenario: A regional insurer needs short-term expertise to define a cloud security architecture. Internal staff understand business processes but lack experience with large cloud transformations.

Which sourcing approach is BEST?

- A. Use qualified external specialists with knowledge-transfer requirements while retaining internal governance and ownership.
- B. Transfer ownership of the architecture permanently to the cloud provider.
- C. Postpone the transformation until all expertise can be hired internally.
- D. Allow the consultant to approve enterprise risk decisions independently.

Question 7 (CISM3-064)

Scenario: A large retailer is considering automation for access provisioning. Manual delays create exposure, but source records are inconsistent and workflow redesign will be required.

Which analysis would BEST support the investment decision?

- A. A comparison based only on product license prices
- B. A business case covering risk reduction, benefits, dependencies, effort, and total cost.
- C. A ranking based on which product has the most automation features
- D. A promise that technology will eliminate all provisioning errors

Question 8 (CISM3-065)

Scenario: A public agency expects several senior security specialists to retire within eighteen months. Their roles support control assurance, supplier oversight, and program reporting, but no successors are prepared.

Which continuity measure should the information security manager establish FIRST?

- A. A plan to replace every specialist with the same job title
- B. A freeze on documentation until replacements are selected
- C. An arrangement for internal audit to operate the vacant capabilities
- D. A competency and succession plan covering knowledge transfer, development, recruitment, and selective sourcing

Question 9 (CISM3-066)

Who should normally approve the classification assigned to a business information asset?

- A. The backup operator
- B. The accountable information owner
- C. The storage administrator
- D. The external auditor

Question 10 (CISM3-067)

Which practice BEST helps keep an information asset inventory useful over time?

- A. Embedding discovery, ownership, and lifecycle updates into business and technology processes.
- B. Updating it only before certification audits
- C. Restricting it to physical hardware purchases
- D. Assigning every asset to the security department

Question 11 (CISM3-068)

Scenario: A film studio labels unreleased content as highly sensitive, yet production partners receive no consistent requirements for transfer, local storage, access, or deletion.

Which program action would BEST close the gap?

- A. Remove classification labels from partner copies.
- B. Require the security team to perform all partner production work.
- C. Define classification-based handling requirements and incorporate them into partner workflows and agreements.
- D. Count the number of sensitive files created each month.

Question 12 (CISM3-069)

Scenario: A financial application deletes customer records from production after the approved retention period, but recoverable copies remain in backups much longer. Neither the information owner nor legal counsel approved the difference.

Which lifecycle action should the information security manager take FIRST?

- A. Disable all backups immediately.
- B. Let infrastructure staff choose the retention period based on storage cost.
- C. Declare backup data outside the information lifecycle.
- D. Engage accountable owners to define requirements and implement a risk-based backup retention and disposal process.

Question 13 (CISM3-070)

What is a security framework MOST useful for during program development?

- A. Accepting residual risk on behalf of business owners
- B. Providing a structured reference for organizing and assessing relevant capabilities
- C. Guaranteeing compliance with every possible obligation
- D. Mandating identical technology for every organization

Question 14 (CISM3-071)

Which criterion should carry the MOST weight when selecting a security framework?

- A. The number of pages in its published guidance
- B. Its fit with organizational objectives, risks, obligations, capabilities, and governance model
- C. Its popularity with one technology supplier
- D. Its ability to eliminate the need for tailoring

Question 15 (CISM3-072)

Scenario: A payment processor enters a market with additional assurance requirements. Management wants a separate control program, although many requirements overlap with existing controls.

Which framework-integration step should the information security manager recommend?

- A. Replace all current controls even when they already meet the required outcomes.
- B. Build a fully separate program without evaluating overlap.
- C. Ignore requirements that use unfamiliar terminology.
- D. Map new requirements to controls and evidence, then address confirmed gaps.

Question 16 (CISM3-073)

Which security document normally states management's high-level direction and intent?

- A. Procedure
- B. Policy
- C. Configuration record
- D. Exception request

Question 17 (CISM3-074)

A company needs to mandate a minimum security configuration across supported servers. Which document is MOST appropriate?

- A. An optional guideline
- B. A program charter
- C. An audit opinion
- D. A security standard

Question 18 (CISM3-075)

Scenario: A sales platform cannot meet a new session-management standard until its planned upgrade. The business requests temporary use of the current design for nine months.

What should be required before approving the request?

- A. A permanent exclusion of the platform from all security standards
- B. Approval from the developer who maintains the session code
- C. Documented risk, accountable approval, compensating measures, monitoring, and a defined expiration and review date
- D. A statement that no incident has previously involved the platform

Question 19 (CISM3-076)

Scenario: A bank centralizes account administration, but local procedures still assign approvals to branch administrators whose roles no longer exist. The governing policy and access standard remain valid.

Which action is MOST appropriate?

- A. Rewrite the policy even though its management direction remains valid.
- B. Allow each branch to invent a replacement approval process.
- C. Update and approve procedures traceable to the existing policy and standard.
- D. Ignore the procedures because the technology has already changed.

Question 20 (CISM3-077)

Scenario: A conglomerate is replacing tightly coupled systems with reusable business services. Security requirements remain application-specific, creating inconsistent identity, encryption, and logging designs.

Which architecture action should the information security manager take FIRST?

- A. Require all services to use the same vendor regardless of requirements.
- B. Let application teams define independent security principles.
- C. Delay security architecture until the transformation is complete.
- D. Define shared security principles and capabilities aligned with the modular enterprise architecture and risk needs.

Question 21 (CISM3-078)

Scenario: A government department has approved a target architecture based on common identity and data services. Current applications use incompatible identifiers, and several cannot be changed for two years.

Which planning activity would provide the MOST value?

- A. Replacing the target architecture with the current application inventory
- B. Allowing each application to define a permanent target state
- C. Requiring immediate migration without assessing service impact
- D. A gap analysis defining dependencies, interim controls, priorities, and convergence milestones.

Question 22 (CISM3-079)

Scenario: An online broker requires customer services to remain available during regional outages. Solution teams propose resilience designs, but reviewers cannot determine whether each design meets the approved business tolerance.

What should the security manager require?

- A. A count of all infrastructure components in each design
- B. Selection of the design with the greatest number of redundant devices
- C. Traceability from business risk requirements to architecture, controls, and acceptance criteria.
- D. Transfer of resilience ownership to internal audit

Question 23 (CISM3-080)

Scenario: A growing software enterprise requires the same lengthy architecture review for minor internal tools and critical customer platforms. Teams increasingly bypass review because the process cannot meet delivery demand.

Which change would BEST improve governance?

- A. Eliminate reviews for every internally hosted solution.
- B. Approve all low-cost projects automatically without requirements.
- C. Use risk-based review tiers, reusable patterns, early checkpoints, and a documented exception process.
- D. Require the architecture team to operate every solution after approval.

Question 24 (CISM3-081)

Scenario: A shipping company must replace fragmented encryption services. One proposal migrates all routes during peak season; another phases migration around route schedules but temporarily maintains two key-management processes.

Which roadmap recommendation should the information security manager make?

- A. Select the peak-season cutover because fewer calendar days always means less risk.
- B. Let each route choose an unrelated encryption architecture.
- C. Retain fragmented services indefinitely to avoid transition risk.
- D. Choose a risk-assessed roadmap with dependency sequencing, interim safeguards, operating ownership, success measures, and rollback criteria.

Question 25 (CISM3-082)

Which metric BEST indicates that an information-classification program is producing its intended outcome?

- A. High-value information with valid ownership, classification, and compliant handling.
- B. Hours spent creating classification presentations
- C. Number of employees invited to classification meetings
- D. Total number of labels available in the system

Question 26 (CISM3-083)

Scenario: Secure-development training completion has reached 100 percent, but the rate of serious defects found before release has not improved. Managers propose declaring the initiative successful.

How should the manager interpret these program results?

- A. Stop measuring defects because the results conflict with training data.
- B. Accept completion as proof that development risk is reduced.
- C. Treat completion as activity; analyze application, adoption, defects, and outcomes.
- D. Increase the number of course slides without examining behavior.

Question 27 (CISM3-084)

Scenario: A healthcare network has limited funds after a maturity assessment. The lowest-scoring capability supports a low-impact process, while a moderately mature identity capability has weaknesses affecting critical clinical applications.

Which investment approach is BEST?

- A. Fund only the lowest numerical score.
- B. Prioritize improvements by risk, business dependence, outcomes, and cost.
- C. Raise every capability by one level regardless of value.
- D. Discard the assessment because maturity cannot inform decisions.

Question 28 (CISM3-085)

Which characteristic is MOST important in a well-designed security control?

- A. It uses the newest available technology.
- B. It is identical to a competitor's control.
- C. It creates the maximum possible restriction.
- D. It addresses a defined risk within business and architecture constraints.

Question 29 (CISM3-086)

Scenario: Field engineers work in locations with unreliable connectivity. A proposed access control requires continuous online verification and could block safety-related maintenance during outages.

What should the security manager recommend?

- A. Assess access and safety needs, then select resilient offline safeguards and monitoring.
- B. Approve the control because stronger restriction always reduces enterprise risk.
- C. Remove all access control from field devices.
- D. Let each engineer disable security controls as needed.

Question 30 (CISM3-087)

Scenario: A publisher encrypts manuscripts during transfer to editors but stores downloaded copies without access restrictions. The documented risk scenario includes misuse after download.

How should the manager close this control-design gap?

- A. Reassess end-to-end coverage and add proportionate controls for downloaded content and its lifecycle.
- B. Increase transfer-encryption strength without reviewing stored copies.
- C. Accept the design because one stage of transfer is encrypted.
- D. Transfer control ownership to the external editors.

Question 31 (CISM3-088)

Scenario: A wholesale marketplace can block all unusual orders automatically or combine targeted blocking with rapid review and monitoring. Full blocking reduces fraud attempts but may reject valuable seasonal orders.

Which basis should guide the selection?

- A. Choose the option with the most restrictive default regardless of business impact.
- B. Compare risk reduction, error impacts, response capacity, resilience, customer needs, and lifecycle cost.
- C. Select the design preferred by the tool supplier.
- D. Use the option with the greatest number of individual rules.

Question 32 (CISM3-089)

Scenario: A university installs a tool to detect exposed research data. No team owns alert decisions, researchers have not been informed, and service processes do not contain an escalation route.

What should occur before implementation is considered complete?

- A. The tool vendor should certify that installation finished.
- B. The project should consume its remaining budget.
- C. Internal audit should become the alert-response owner.
- D. Establish operating ownership, procedures, integration, escalation, and acceptance criteria.

Question 33 (CISM3-090)

Scenario: A streaming company performs one security review immediately before releasing each service. Repeated late findings cause launch delays and exceptions.

Which program change is MOST appropriate?

- A. Embed proportionate requirements, design review, testing, and acceptance into existing product lifecycle checkpoints.
- B. Increase final review duration without changing earlier delivery stages.
- C. Let product teams accept all security risk without governance.
- D. Require internal audit to design every product control.

Question 34 (CISM3-091)

Scenario: A logistics firm launches a new supplier-access approval process. Requests accumulate because approvers were not assigned for several regions and the system does not route absences to delegates.

Which initial action would BEST improve operational adoption?

- A. Assign approvers and delegates, correct routing, and manage backlog by risk.
- B. Report success because the workflow system is available.
- C. Ask the security team to approve all supplier access permanently.
- D. Increase the number of policy reminders sent to suppliers.

Question 35 (CISM3-092)

Scenario: An airline pilots a new administrator-verification control in its corporate environment. The pilot is successful, but airport maintenance systems use different support procedures and were not represented.

Which deployment decision BEST reflects the available evidence?

- A. Cancel the control because the pilot did not cover every environment.
- B. Deploy to every airport immediately because the corporate pilot passed.
- C. Expand through risk-based phases after validating airport workflows, support readiness, acceptance criteria, and rollback arrangements.
- D. Let local administrators decide whether the control applies.

Question 36 (CISM3-093)

Scenario: A payroll company uses an automated rule to prevent conflicting payment roles. The rule passed testing at launch, but role mappings and interfaces have changed several times since then.

What should the next control evaluation include?

- A. Current design validation, change coverage, complete population testing, exception handling, and evidence of operation
- B. A statement from the developer that the rule remains enabled
- C. Only the original launch approval document
- D. A count of employees who can view the control dashboard

Question 37 (CISM3-094)

Scenario: Monthly reviews repeatedly find unapproved shared accounts in several warehouses. Local teams delete the accounts after each review, but new ones appear because temporary workers need rapid access.

Which remediation action should the information security manager take NEXT?

- A. Close each finding once the identified accounts are deleted.
- B. Require root-cause analysis and owned remediation for temporary-worker provisioning.
- C. Increase review report length without changing the access process.
- D. Transfer warehouse account operation to the assurance team.

Question 38 (CISM3-095)

Which arrangement provides the STRONGEST assurance objectivity?

- A. The control operator selects successful samples and approves the conclusion.
- B. An independent competent party selects evidence and reports through governance.
- C. The control owner limits reviewers to evidence already used for monthly reporting.
- D. The security manager replaces all operational monitoring with a periodic audit.

Question 39 (CISM3-096)

Scenario: A data center meets a contractual checklist for physical access. However, repeated tailgating observations and unresolved door alarms affect restricted areas.

Which effectiveness conclusion should the information security manager reach?

- A. Door alarms are irrelevant because access procedures are documented.
- B. Contractual conformity proves that residual physical risk is acceptable.
- C. Checklist conformity is insufficient; evaluate operating failures and resulting risk.
- D. Further review should wait until unauthorized access causes a confirmed loss.

Question 40 (CISM3-097)

Why should security training be tailored to job roles?

- A. To build role-specific knowledge and risk-reducing behavior.
- B. To transfer control ownership to every trainee
- C. To eliminate the need for general awareness
- D. To make policy requirements optional for specialized employees

Question 41 (CISM3-098)

Scenario: Hospital schedulers often disclose more patient information than necessary when coordinating with external clinics. They completed general privacy training, but the scheduling process gives no disclosure guidance.

Which training improvement is MOST appropriate for this workflow?

- A. Provide role-based scenario training, workflow prompts, reinforcement, and behavior measurement.
- B. Make the security team conduct every scheduling call.
- C. Repeat the same general course for all hospital employees.
- D. Measure only whether schedulers acknowledge the privacy policy.

Question 42 (CISM3-099)

Scenario: A call center reports perfect completion of identity-verification training. Quality reviews still find that agents skip required challenge steps when call queues are long.

Which measure should receive the MOST attention?

- A. The total duration of the training modules
- B. The number of reminder messages sent by security
- C. The percentage of agents who opened the course invitation
- D. Correct verification behavior under representative conditions, segmented by team and cause.

Question 43 (CISM3-100)

Scenario: A manufacturer wants an external provider to operate remote connectivity to factory systems. Procurement has evaluated price and availability but not privileged access, subcontractors, incident duties, or termination.

What should the information security manager require before approval?

- A. Transfer of all operational risk to the provider through a general clause
- B. Reliance on the provider's marketing description of its security
- C. Risk-based due diligence and defined access, evidence, incident, subcontractor, monitoring, continuity, and exit requirements
- D. Approval based only on the lowest bid

Question 44 (CISM3-101)

Scenario: A document-processing provider moves part of its service to a new subcontractor without the required notice. The subcontractor will receive confidential records and operates under different legal conditions.

Which response should the manager take FIRST regarding this provider change?

- A. Ignore the change because the direct provider remains accountable.
- B. Assess the change, invoke contract rights, and require approved treatment before processing.
- C. Assume direct operational control of the subcontractor.
- D. Wait until the next annual supplier review.

Question 45 (CISM3-102)

Scenario: A research organization ends a laboratory data service. The provider returns the primary database but says backup deletion follows an unspecified internal schedule, and two provider administrators retain active accounts.

How should the manager handle this incomplete provider exit?

- A. Accept the provider's verbal statement as conclusive evidence.
- B. Close the exit because the primary database was returned.
- C. Keep exit open until access, data return, retention, deletion, and contracts are resolved.
- D. Leave provider accounts active in case historical support is needed.

Question 46 (CISM3-103)

Scenario: A board committee receives a quarterly security report containing project completion percentages but no indication of risk reduction, control performance, or decisions required.

How should the report be improved?

- A. Add more task-level project schedules without explaining outcomes.
- B. Show outcome and risk trends, business implications, decisions, and owners.
- C. Report only initiatives that are on schedule.
- D. Replace the report with raw technical event logs.

Question 47 (CISM3-104)

Scenario: A data-retention initiative cannot proceed because several business owners have not classified their records. The delay now threatens a regulatory milestone and exceeds the program's escalation threshold.

Which escalation action should the information security manager take NEXT?

- A. Classify every business record without owner involvement.
- B. Escalate impact, evidence, dependencies, options, and the required decision.
- C. Move the milestone so the dashboard remains green.
- D. Omit the dependency from reporting until owners respond.

Question 48 (CISM3-105)

Scenario: A manufacturing safety team resists a proposed device restriction because it could delay emergency maintenance. Security presented the control only after selecting the design.

Which approach would BEST rebuild effective engagement?

- A. Define security and safety outcomes, alternatives, decisions, and measures jointly.
- B. Ask the safety team to accept all information risk independently.
- C. Enforce the selected design without reviewing safety impact.
- D. Cancel all device security requirements to avoid disagreement.

Question 49 (CISM3-106)

Scenario: A telecommunications company reorganizes from regional operations to product lines. Security controls still route approvals and metrics to former regional roles.

Which maintenance action should the information security manager take FIRST?

- A. Wait for control failures before updating the program.
- B. Keep former approvers indefinitely because controls should not change.
- C. Assign every approval to the central security team.
- D. Assess risks, ownership, workflows, and reporting, then update program controls.

Question 50 (CISM3-107)

Scenario: A pharmaceutical company wants to use a new data-analysis service for sensitive trial information. Proposed benefits are significant, but data use, model outputs, provider dependencies, and existing control coverage are unclear.

Which program approach is MOST appropriate for this proposed capability?

- A. Assess use cases, set data guardrails, run a bounded pilot, and update controls.
- B. Permit unrestricted use until a confirmed loss occurs.
- C. Ban the capability permanently because current policies do not name it.
- D. Let each research team create separate requirements and provider terms.

Answer Key

Domain III - Information Security Program

1 C	2 D	3 B	4 A	5 C
6 A	7 B	8 D	9 B	10 A
11 C	12 D	13 B	14 B	15 D
16 B	17 D	18 C	19 C	20 D
21 D	22 C	23 C	24 D	25 A
26 C	27 B	28 D	29 A	30 A
31 B	32 D	33 A	34 A	35 C
36 A	37 B	38 B	39 C	40 A
41 A	42 D	43 C	44 B	45 C
46 B	47 B	48 A	49 D	50 A

Detailed Explanations

Question 1 (CISM3-058)

Correct answer: C - The subscription model's critical services, information, obligations, dependencies, and risks

Program objectives should reflect the new service's business needs, information, obligations, dependencies, and risk exposure. Product features and competitor practices may inform options, while excluding product teams would prevent alignment with the new operating model.

Question 2 (CISM3-059)

Correct answer: D - Develop an approved charter defining enterprise authority, local responsibilities, scope, objectives, and escalation.

An approved charter provides the authority and shared-accountability model needed for a decentralized program. Procedures cannot create the mandate, audit should remain independent, and unrelated local mandates would deepen fragmentation.

Question 3 (CISM3-060)

Correct answer: B - Prioritize by risk reduction, capability dependencies, deployment milestones, and available capacity.

A defensible roadmap sequences work around risk, dependencies, business milestones, and delivery capacity. Visibility and alphabetical order do not establish value, while delaying foundational capabilities would expose the plant connections.

Question 4 (CISM3-061)

Correct answer: A - Include shared risks, define corporate and franchise duties, and set interface requirements.

Scope should follow shared services, information, brand obligations, and risk while assigning responsibilities across ownership boundaries. Local ownership and incident history do not remove exposure, and a platform operator cannot own all franchise business risk.

Question 5 (CISM3-062)

Correct answer: C - Expected workload, service levels, skill coverage, resilience needs, and sourcing options

Continuous operation requires capacity based on workload, coverage, competence, service expectations, and resilience, including appropriate sourcing. Unrelated headcount, previous requests, and project costs do not establish operational needs.

Question 6 (CISM3-063)

Correct answer: A - Use qualified external specialists with knowledge-transfer requirements while retaining internal governance and ownership.

Targeted external expertise can close the immediate gap while knowledge transfer and internal ownership preserve continuity and business alignment. Consultants and providers should not own enterprise risk decisions, and indefinite delay is unnecessary when sourcing is governed.

Question 7 (CISM3-064)

Correct answer: B - A business case covering risk reduction, benefits, dependencies, effort, and total cost.

The business case must account for both benefits and prerequisites, including poor source data and workflow change, across the investment lifecycle. License price and feature count are incomplete, and no technology can credibly guarantee elimination of every error.

Question 8 (CISM3-065)

Correct answer: D - A competency and succession plan covering knowledge transfer, development, recruitment, and selective sourcing

A competency-based succession plan addresses future capability needs through several coordinated options and protects institutional knowledge. Matching titles may not match future needs, withholding documentation increases dependence, and internal audit should not operate management capabilities.

Question 9 (CISM3-066)

Correct answer: B - The accountable information owner

The information owner has the business accountability to approve classification and associated handling needs. Operators and administrators provide custody, while auditors independently assess whether ownership and classification processes are effective.

Question 10 (CISM3-067)

Correct answer: A - Embedding discovery, ownership, and lifecycle updates into business and technology processes.

Inventory maintenance should be integrated with processes that create, change, transfer, and retire information assets. Audit-only updates become stale, hardware-only scope misses information, and security does not own every business asset.

Question 11 (CISM3-068)

Correct answer: C - Define classification-based handling requirements and incorporate them into partner workflows and agreements.

Classification must drive clear handling requirements across internal and partner workflows, supported by appropriate agreements. Removing labels hides sensitivity, centralizing business work is impractical, and file counts do not establish protection.

Question 12 (CISM3-069)

Correct answer: D - Engage accountable owners to define requirements and implement a risk-based backup retention and disposal process.

Backup copies remain within the information lifecycle and require owner-approved retention and defensible disposal aligned with business and legal needs. Disabling backups can harm resilience, cost alone is not decisive, and storage form does not remove accountability.

Question 13 (CISM3-070)

Correct answer: B - Providing a structured reference for organizing and assessing relevant capabilities

A framework offers a structured reference for organizing and assessing program capabilities when tailored to context. It does not own risk decisions, guarantee universal compliance, or mandate the same technology in every enterprise.

Question 14 (CISM3-071)

Correct answer: B - Its fit with organizational objectives, risks, obligations, capabilities, and governance model

Framework selection should be driven by organizational fit and the ability to support relevant outcomes and governance. Length and supplier preference are weak criteria, and every framework requires contextual interpretation rather than eliminating tailoring.

Question 15 (CISM3-072)

Correct answer: D - Map new requirements to controls and evidence, then address confirmed gaps.

Mapping preserves useful existing controls, supports traceability, and focuses investment on real gaps. A separate program duplicates effort, terminology differences do not remove obligations, and wholesale replacement wastes effective capabilities.

Question 16 (CISM3-073)

Correct answer: B - Policy

Policy communicates management's authoritative direction and intent. Procedures describe how work is performed, configuration records document implementation details, and exception requests seek approval to deviate from a requirement.

Question 17 (CISM3-074)

Correct answer: D - A security standard

A standard establishes specific mandatory requirements that support policy direction. Guidelines are advisory, a charter establishes program authority, and an audit opinion assesses conditions rather than prescribing operational configuration.

Question 18 (CISM3-075)

Correct answer: C - Documented risk, accountable approval, compensating measures, monitoring, and a defined expiration and review date

A controlled exception requires an explicit risk basis, proper authority, interim protection, oversight, and a time limit. Permanent exclusion avoids governance, a developer may not own the risk, and incident history alone does not demonstrate acceptability.

Question 19 (CISM3-076)

Correct answer: C - Update and approve procedures traceable to the existing policy and standard.

The obsolete operational steps should be updated through controlled document maintenance while remaining traceable to valid governing requirements. Unnecessary policy revision wastes effort, local improvisation creates inconsistency, and stale procedures continue to create operational risk.

Question 20 (CISM3-077)

Correct answer: D - Define shared security principles and capabilities aligned with the modular enterprise architecture and risk needs.

Shared principles and capabilities align security with the enterprise's modular direction and provide consistent design guidance. Vendor uniformity is not architectural alignment, team-specific principles fragment the model, and late architecture would miss important design decisions.

Question 21 (CISM3-078)

Correct answer: D - A gap analysis defining dependencies, interim controls, priorities, and convergence milestones.

A transition analysis makes the target achievable by identifying dependencies, temporary states, risks, controls, and milestones. Treating the current inventory as the target prevents improvement, immediate migration may disrupt services, and independent targets preserve incompatibility.

Question 22 (CISM3-079)

Correct answer: C - Traceability from business risk requirements to architecture, controls, and acceptance criteria.

Traceability shows whether designs and controls actually satisfy approved resilience needs and provides a basis for acceptance. Component counts and maximum redundancy do not establish fitness, while audit should independently assess rather than own resilience.

Question 23 (CISM3-080)

Correct answer: C - Use risk-based review tiers, reusable patterns, early checkpoints, and a documented exception process.

Risk tiers and reusable patterns focus oversight where it matters while retaining requirements and accountable exceptions. Broad exclusions and cost-only approval can miss significant risk, and architecture governance does not require operating every solution.

Question 24 (CISM3-081)

Correct answer: D - Choose a risk-assessed roadmap with dependency sequencing, interim safeguards, operating ownership, success measures, and rollback criteria.

A governed roadmap should balance target-state improvement with transition risk and operational feasibility through explicit safeguards and criteria. Schedule length alone is not decisive, indefinite delay preserves weaknesses, and independent architectures perpetuate fragmentation.

Question 25 (CISM3-082)

Correct answer: A - High-value information with valid ownership, classification, and compliant handling.

Valid ownership, classification, and compliant handling demonstrate the program's intended governance result. Presentation hours, invitations, and label counts are activity or design measures that do not establish effective use.

Question 26 (CISM3-083)

Correct answer: C - Treat completion as activity; analyze application, adoption, defects, and outcomes.

Completion shows participation, not whether behavior or security outcomes improved. Application and defect analysis can reveal training or process gaps, while ignoring outcomes or simply adding content would not support a sound effectiveness conclusion.

Question 27 (CISM3-084)

Correct answer: B - Prioritize improvements by risk, business dependence, outcomes, and cost.

Maturity information should be combined with risk, criticality, outcome needs, and economics, which may favor the identity capability. Score-only and uniform investment ignore impact, while discarding the assessment loses a useful input.

Question 28 (CISM3-085)

Correct answer: D - It addresses a defined risk within business and architecture constraints.

A sound design is traceable to the intended objective and risk and fits relevant requirements and operating constraints. Technology age, competitor use, and maximum restriction do not demonstrate suitability or proportionality.

Question 29 (CISM3-086)

Correct answer: A - Assess access and safety needs, then select resilient offline safeguards and monitoring.

The control should address access risk while remaining safe and effective under expected connectivity conditions. Absolute restriction can create operational risk, removing controls abandons the objective, and discretionary disabling lacks consistent governance.

Question 30 (CISM3-087)

Correct answer: A - Reassess end-to-end coverage and add proportionate controls for downloaded content and its lifecycle.

The control set must address the complete information path, including use and storage after transfer. Stronger transport encryption does not address downloaded copies, and external editors do not replace the publisher's program accountability.

Question 31 (CISM3-088)

Correct answer: B - Compare risk reduction, error impacts, response capacity, resilience, customer needs, and lifecycle cost.

Control strategy should balance effectiveness with error consequences, operational response, resilience, customer impact, and cost. Restrictiveness, supplier preference, and rule count do not by themselves demonstrate the best overall risk treatment.

Question 32 (CISM3-089)

Correct answer: D - Establish operating ownership, procedures, integration, escalation, and acceptance criteria.

A control is implemented only when the supporting people, process, technology, and governance can operate together and meet acceptance criteria. Installation and budget use are insufficient, and internal audit should not own routine response.

Question 33 (CISM3-090)

Correct answer: A - Embed proportionate requirements, design review, testing, and acceptance into existing product lifecycle checkpoints.

Lifecycle integration identifies and resolves issues when changes are easier and aligns security work with delivery risk. A larger final review remains late, product teams still need authorized risk governance, and audit should independently assess rather than design controls.

Question 34 (CISM3-091)

Correct answer: A - Assign approvers and delegates, correct routing, and manage backlog by risk.

The adoption failure stems from incomplete ownership and workflow design, which should be corrected while the backlog is prioritized by risk. Reminders do not fix routing, availability is not effective operation, and permanent security-team approval would displace business accountability.

Question 35 (CISM3-092)

Correct answer: C - Expand through risk-based phases after validating airport workflows, support readiness, acceptance criteria, and rollback arrangements.

A phased, criteria-based rollout uses the positive evidence while addressing distinct airport dependencies and operational risk. Immediate enterprise deployment overgeneralizes the pilot, cancellation discards a viable control, and local discretion would undermine consistent governance.

Question 36 (CISM3-093)

Correct answer: A - Current design validation, change coverage, complete population testing, exception handling, and evidence of operation

Changed mappings and interfaces require current evidence that the rule remains complete, correctly designed, and operational, including exceptions. Launch approval and developer statements are insufficient, while dashboard access does not test the control objective.

Question 37 (CISM3-094)

Correct answer: B - Require root-cause analysis and owned remediation for temporary-worker provisioning.

Recurring accounts indicate a systemic provisioning need that record-level deletion does not resolve. Root-cause remediation with ownership and outcome tracking is sustainable, while larger reports do not fix the process and assurance should not operate it.

Question 38 (CISM3-095)

Correct answer: B - An independent competent party selects evidence and reports through governance.

Independence from operation, suitable evidence selection, and an appropriate reporting line support objective assurance. Operator-selected success samples and owner restrictions create bias, while independent reviews complement rather than replace management monitoring.

Question 39 (CISM3-096)

Correct answer: C - Checklist conformity is insufficient; evaluate operating failures and resulting risk.

Compliance evidence does not override direct evidence that controls are failing in operation or determine risk acceptance. Documentation alone cannot negate tailgating and alarms, and waiting for loss would abandon proactive assurance and remediation.

Question 40 (CISM3-097)

Correct answer: A - To build role-specific knowledge and risk-reducing behavior.

Role-based training prepares people for the specific decisions, responsibilities, and risk contexts in their work. It does not make policy optional, transfer ownership automatically, or remove the value of baseline awareness.

Question 41 (CISM3-098)

Correct answer: A - Provide role-based scenario training, workflow prompts, reinforcement, and behavior measurement.

Role-specific examples and in-workflow prompts address the actual disclosure decisions and support measurable reinforcement. Generic repetition remains indirect, centralizing calls is impractical, and acknowledgement does not demonstrate correct behavior.

Question 42 (CISM3-099)

Correct answer: D - Correct verification behavior under representative conditions, segmented by team and cause.

Observed behavior under the conditions driving failure measures the intended risk-reducing result and helps target action. Course duration, reminders, and invitation opens are activity measures that do not demonstrate effective verification.

Question 43 (CISM3-100)

Correct answer: C - Risk-based due diligence and defined access, evidence, incident, subcontractor, monitoring, continuity, and exit requirements

The critical service requires lifecycle governance covering access, assurance, dependencies, events, continuity, and exit. A contract cannot transfer all organizational risk, marketing is weak evidence, and price alone does not establish security suitability.

Question 44 (CISM3-101)

Correct answer: B - Assess the change, invoke contract rights, and require approved treatment before processing.

An unapproved material dependency requires immediate assessment and use of contractual governance before sensitive processing continues. Direct-provider accountability does not remove fourth-party risk, the customer should not operate the subcontractor, and annual review is too late.

Question 45 (CISM3-102)

Correct answer: C - Keep exit open until access, data return, retention, deletion, and contracts are resolved.

Exit is incomplete while provider access and unverified backup copies remain, so evidence and accountable closure are required. Returning the primary database alone is insufficient, verbal assurance is weak, and unnecessary active accounts preserve exposure.

Question 46 (CISM3-103)

Correct answer: B - Show outcome and risk trends, business implications, decisions, and owners.

Governance reporting should show whether the program is achieving intended outcomes, what the risk implications are, and who must decide or act. More activity detail, positive-only reporting, and raw logs do not provide that decision context.

Question 47 (CISM3-104)

Correct answer: B - Escalate impact, evidence, dependencies, options, and the required decision.

The defined threshold and threatened obligation require transparent escalation to those with authority over the dependencies. Security should not replace information owners, moving dates can conceal exposure, and omission prevents timely governance action.

Question 48 (CISM3-105)

Correct answer: A - Define security and safety outcomes, alternatives, decisions, and measures jointly.

Joint, outcome-focused analysis addresses both security and safety while clarifying decision authority and success measures. Unilateral enforcement or risk transfer undermines ownership, and removing requirements abandons the security objective.

Question 49 (CISM3-106)

Correct answer: D - Assess risks, ownership, workflows, and reporting, then update program controls.

The restructuring changes accountability and operating processes, so affected controls and program artifacts need timely reassessment and update. Obsolete roles cannot provide reliable approval, centralizing all decisions may misassign ownership, and waiting is reactive.

Question 50 (CISM3-107)

Correct answer: A - Assess use cases, set data guardrails, run a bounded pilot, and update controls.

A governed pilot supports innovation while addressing data, architecture, provider, and outcome risks and informing program evolution. Unrestricted use lacks safeguards, a permanent ban avoids proportionate evaluation, and separate team rules fragment governance.